

Azure Blob Storage Configuration Review

Corporate Policy RAG Project

Overall assessment: The current storage account is suitable for Phase 1 development and basic RAG testing. The main improvements are to use managed identities, disable storage account key access after validation, and restrict the public network endpoint before production.

1. Configuration Review

Setting	Current	Recommendation	Reason
Hierarchical namespace	Disabled	Keep disabled	A standard Blob Storage account is appropriate for policy documents. Data Lake Storage Gen2 capabilities are not required for a basic RAG solution.
Default access tier	Hot	Keep	Appropriate while documents are actively indexed, re-indexed, and tested.
Blob anonymous access	Disabled	Keep	Corporate policy documents should require authenticated access.
Blob soft delete	Enabled - 7 days	Good for development	Consider 14-30 days for production recovery needs.
Container soft delete	Enabled - 7 days	Good for development	Consider 14-30 days for production.
Versioning	Disabled	Consider enabling	Useful in production to recover a policy file that was accidentally overwritten or changed.
Change feed	Disabled	Keep disabled for now	Not required for basic

Setting	Current	Recommendation	Reason
			indexing. Enable only for detailed change tracking, event-driven processing, or point-in-time restore requirements.
NFS v3	Disabled	Keep	The RAG solution should use Blob APIs rather than NFS.
Cross-tenant replication	Disabled	Keep	No apparent need to replicate corporate policy data into another Microsoft Entra tenant.
Secure transfer required	Enabled	Keep	Ensures REST API operations use HTTPS.
Storage account key access	Enabled	Temporary only	Use Microsoft Entra ID, Azure RBAC, and managed identities. Disable Shared Key access after the solution is working.
Minimum TLS version	1.2	Keep	Appropriate minimum transport security setting.
Infrastructure encryption	Disabled	Acceptable	Azure Storage data is already encrypted at rest. A second encryption layer is usually reserved for stronger regulatory or contractual requirements.
Public network access	Enabled from all networks	Restrict before production	Acceptable temporarily for early development, but the endpoint remains publicly reachable and depends on authentication and

Setting	Current	Recommendation	Reason
			authorization for protection.
Private endpoints	0	Acceptable for Phase 1	Add a private endpoint when implementing production network isolation.
Network routing	Microsoft network routing	Keep	Appropriate default routing choice.

2. Most Important Issue: Public Network Access

“Public network access enabled” does not mean the blobs are anonymous. Anonymous Blob access is disabled in the screenshot. However, the storage endpoint is reachable over the public internet, so protection depends on authentication, authorization, network rules, and HTTPS.

- For early development, public access can remain enabled while you validate indexing and integration.
- Use Microsoft Entra ID, Azure RBAC, and managed identities rather than embedding account keys in application code.
- Before production, restrict access to selected networks or disable the public endpoint and use private endpoints.

Recommended Production Approach

- Create a private endpoint for the Blob Storage account.
- Disable public network access when the application, Azure AI Search, and related services can reach storage privately.
- Validate name resolution, virtual network integration, and service connectivity before enforcing the restriction.

Intermediate Development Approach

A lower-risk transition is to change the scope from **Enable from all networks** to **Enable from selected virtual networks and IP addresses**. Allow only the developer IP addresses and Azure resources that require access. Apply this carefully because overly restrictive rules can interrupt Azure AI Search indexing or Foundry connectivity.

3. Recommended Identity and Authorization Model

Use managed identities and least-privilege Azure RBAC assignments. A typical ingestion path is:

```

Azure AI Search managed identity
|
| Storage Blob Data Reader
v
Corporate Policy Blob Container

```

- Grant Azure AI Search the Storage Blob Data Reader role when it only needs to read and index documents.
- If a Microsoft Foundry project must write to the storage account, it may require Storage Blob Data Contributor. Grant that only when write access is actually required.
- Assign roles at the container scope where practical instead of the entire storage account.
- Do not store storage account keys or connection strings in React code or source control.

4. Recommended Phase 1 Settings

For development and basic RAG testing, the following configuration is reasonable:

```
Blob anonymous access:    Disabled
Secure transfer required: Enabled
Minimum TLS:             1.2
Blob soft delete:        Enabled, 7-14 days
Container soft delete:    Enabled, 7-14 days
Versioning:              Optional during Phase 1
Storage account key access: Enabled temporarily
Public network access:    Enabled temporarily
Authentication:          Managed identity + Azure RBAC
```

5. Production Hardening Checklist

- ☐ Confirm Azure AI Search can read the policy container using its managed identity.
- ☐ Confirm Azure Functions or other backend services use managed identity rather than storage keys.
- ☐ Disable storage account key access after all dependencies use Microsoft Entra authentication.
- ☐ Enable Blob versioning for recovery from accidental replacements or edits.
- ☐ Increase soft-delete retention to approximately 14-30 days according to recovery requirements.
- ☐ Restrict public network access to selected networks or disable it entirely.
- ☐ Create and test private endpoints and private DNS resolution.
- ☐ Review RBAC assignments and remove broad roles that are no longer needed.
- ☐ Enable monitoring and alerts for authorization failures, unusual access patterns, and indexing errors.

6. Priority Order

Priority	Action	Purpose
1	Managed identity and RBAC	Establish secure service-to-service authentication first.
2	Disable account-key access	Do this after confirming no component depends on Shared Key authentication.
3	Versioning and retention	Improve recoverability for important policy documents.
4	Network isolation	Restrict public access and introduce

		private endpoints before production.
5	Monitoring and governance	Add alerts, access reviews, and operational controls.